

DB11

北京市地方标准

DB11/T 2328.6—2025

车路云一体化路侧基础设施 第6部分： 信息安全技术要求

side infrastructure of Vehicle-Road-Cloud integration——Part6:
Technical requirements for cybersecurity

2025 - 09 - 23 发布

2026 - 01 - 01 实施

北京市市场监督管理局 发布

目 次

前言..... 11

1 范围..... 1

2 规范性引用文件..... 1

3 术语和定义..... 1

4 缩略语..... 2

5 信息安全架构..... 2

6 通用安全要求..... 2

7 通信网络安全要求..... 5

8 软件升级安全要求..... 6

9 数据安全要求..... 7

参 考 文 献..... 9

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是DB11/T 2328《车路云一体化路侧基础设施》的第6部分，DB11/T 2328已经发布了以下部分：

- 第1部分：建设指南；
- 第2部分：道路交通信号控制机信息服务技术指南；
- 第3部分：摄像机应用技术要求；
- 第4部分：毫米波雷达应用技术要求；
- 第5部分：边缘计算设备应用技术要求。

本文件由北京市经济和信息化局提出并归口。

本文件由北京市经济和信息化局组织实施。

本文件起草单位：北京车网科技发展有限公司、中国信息通信研究院、公安部第三研究所、密码科技国家工程研究中心、北京市标准化研究院、北京小马易行科技有限公司、中信科智联科技有限公司、杭州海康威视数字技术股份有限公司、北京网御星云信息技术有限公司、北京梆梆安全科技有限公司、格尔软件股份有限公司、北京星云互联科技有限公司、郑州信大捷安信息技术股份有限公司、兴唐通信科技有限公司、北京百度网讯科技有限公司、北京市商汤科技开发有限公司、北京数字认证股份有限公司、北京新能源汽车股份有限公司。

本文件主要起草人：孙宁、宋娟、高凤飞、王楠、霍俊江、路鹏飞、郑方丹、王运、刘羽涵、王艳、时慧、岳锦涛、谢勃毅、周唯、王威然、王赛、陈杰、于广琛、吴昊、赵劲涛、王雪、郭丽丹、侯建宁、刘帅、尹立芳、穆同娜、杨萌、孔维佳、田川、张舒涵、蔡一宁、吴淳豆、房家奕、杨天、齐绩、谢晨、孔得亮、王斌、史岩、阚志刚、林凯、孙皇龙、牟杰、鲁双双、王易之、张广岐、刘为华、梁承志、朱双贺、路宏、周雪琪、严格、王新华、王本海、韩增杨。

引 言

本系列文件通过提出车路云一体化路侧基础设施的组成及架构、建设要求、运维要求、信息安全要求等内容，为车路云一体化路侧基础设施设计、开发、集成提供参考，有效推动车路云一体化路侧基础设施的标准化建设。本系列文件拟分为7个部分。

——第1部分：建设指南。目的在于规范车路云一体化路侧基础设施的基本构成、总体要求、技术要求等内容。

——第2部分：道路交通信号控制机信息服务技术指南。目的在于规范道路交通信号控制机提供信息服务的基础条件、信息格式和消息内容。

——第3部分：摄像机应用技术要求。目的在于规范车路云一体化摄像机的接口要求、功能要求、安全要求等内容。

——第4部分：毫米波雷达应用技术要求。目的在于规范车路云一体化毫米波雷达的功能要求、通信要求、安装要求等内容。

——第5部分：边缘计算设备应用技术要求。目的在于规范车路云一体化边缘计算设备的软件架构要求、接口要求、功能要求、性能要求等内容。

——第6部分：信息安全技术要求。目的在于规范车路云一体化路侧基础设施中通用安全要求、通信网络安全要求、软件升级安全要求、数据安全要求等内容。

——第7部分：运维管理系统应用技术要求。目的在于规范车路云一体化路侧基础设施中不同类型设备的运维管理规范内容。

车路云一体化路侧基础设施 第6部分：信息安全技术要求

1 范围

本文件规定了车路云一体化系统中路侧基础设施的信息安全技术要求，其中包括通用安全要求、通信网络安全要求、软件升级安全要求、数据安全要求的内容。

本文件适用于车路云一体化系统中具备操作系统的路侧基础设施的信息安全的设计、实现和运维。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 15852（所有部分） 信息技术 安全技术 消息鉴别码
GB/T 20518 信息安全技术 公钥基础设施 数字证书格式
GB/T 32905 信息安全技术 SM3密码杂凑算法
GB/T 32907 信息安全技术 SM4分组密码算法
GB/T 32918（所有部分） 信息安全技术 SM2椭圆曲线公钥密码算法
GB/T 35275 信息安全技术 SM2密码算法加密签名消息语法规则
GB/T 35276 信息安全技术 SM2密码算法使用规范
GB/T 39786 信息安全技术 信息系统密码应用基本要求
YD/T 3957 基于LTE的车联网无线通信技术 安全证书管理系统技术要求
DB11/T 2328.1 车路云一体化路侧基础设施 第1部分：建设指南
DB11/T 2328.5 车路云一体化路侧基础设施 第5部分：边缘计算设备应用技术要求

3 术语和定义

DB11/T 2328.1和DB11/T 2328.5界定的以及下列术语和定义适用于本文件。

3.1

路侧通信单元 roadside communication unit

设置于道路路侧或龙门架等位置，具备无线或有线连接方式的产品或功能集成产品。

3.2

路侧基础设施管理系统 roadside infrastructure management system

对路侧基础设施进行接入、认证、授权、审计日志收集、配置策略下发等统一管理的系统。

3.3

重要数据 important data

一旦遭到篡改、破坏、泄露或者非法获取、非法利用，可能危害国家安全、公共利益或者个人、组织合法权益的数据。

[来源：数据安全法，第二十一条]

3.4

安全启动 secure boot

对系统启动中的各个组件进行逐级验证，实现路侧通信单元和边缘计算设备的安全启动。

4 缩略语

以下缩略语适用于本文件。

PCB：印制电路板（Printed Circuit Board）

TLCP：传输层密码协议（Transport layer cryptography protocol）

TLS：传输层安全协议（Transport Layer Security）

5 信息安全架构

车路云一体化路侧基础设施信息安全架构见图1。

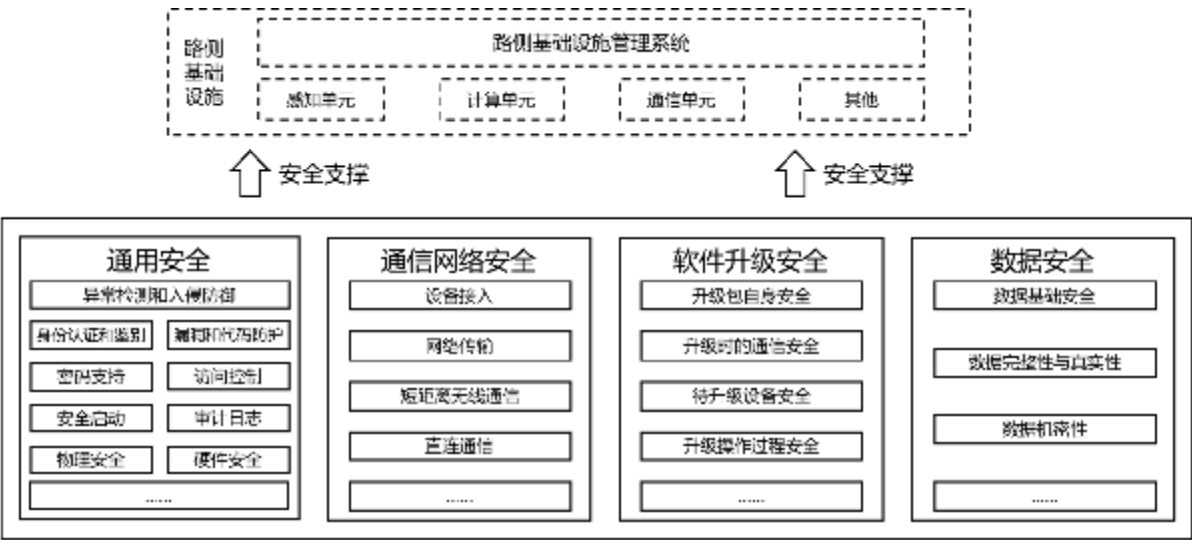


图 1 车路云一体化路侧基础设施信息安全架构图

6 通用安全要求

6.1 物理安全

6.1.1 路侧基础设施应结合其应用及安全需求，采取防物理破坏、防雷、防水、防尘等措施。所处物理环境不应会对设施造成物理破坏，如挤压、强振动等。

6.1.2 路侧基础设施应具备可供 7×24 小时工作的稳定电力供应。

6.1.3 宜参照 GB/T 22239 等级保护第二级及以上安全物理环境要求。

6.2 硬件安全

6.2.1 硬件 PCB 应关闭非必要的调试接口，不应存在后门或隐蔽接口，调试接口应禁用或设置安全访问控制。

6.2.2 硬件 PCB 及芯片不应暴露用以标注端口和管脚功能的可读丝印。

6.2.3 用于存储重要数据的关键芯片及安全芯片，应减少暴露管脚。

6.2.4 宜具备侧信道攻击（功耗差分分析、电磁差分分析、电流故障注入、电磁故障注入等）的防范

措施。

6.3 安全启动

6.3.1 路侧通信单元和边缘计算设备应具备安全启动功能。

6.3.2 路侧通信单元和边缘计算设备可基于可信根对系统引导程序、系统程序等进行可信验证；可通过可信根实体对安全启动所使用的可信根进行保护，可信根实体包括非易失性存储器（OTP）、可信平台模块（TPM）、可信密码模块（TCM）、可信平台控制模块（TPCM）等，可信根实体应当具备一次性写入不可修改特性。

6.3.3 安全启动覆盖范围宜至少引导程序到系统内核。

6.4 审计日志

6.4.1 审计日志事件应包括但不限于：用户登录、用户操作、配置变更和信息安全事件等。

6.4.2 审计日志内容应包括但不限于：事件的时间、操作 IP 地址、主体标识、客体标识、类型和结果等。

6.4.3 审计日志中应禁止以明文形式存储密钥（不含公钥与证书）、口令等信息。

6.4.4 应具有访问控制机制，防止对审计日志进行非授权访问，避免受到非预期的删除、修改或覆盖等。

6.4.5 审计日志应定期备份，审计日志保留时间不应少于 6 个月。

6.5 身份认证和鉴别

6.5.1 路侧基础设施对用户的身份认证和鉴别功能，使用口令鉴别方式时，应支持首次登录时强制修改默认口令或设置口令，支持设置口令生存周期不长于 3 个月，支持口令复杂度检查、口令错误次数限制。

6.5.2 路侧基础设施之间的身份认证和鉴别功能，应具备可用于通信识别的唯一标识，如采用设备身份标识号码 ID、序列号、媒体存取控制地址（MAC 地址）或其组合等作为唯一标识；应基于唯一标识或结合密码技术进行身份认证和鉴别。

6.5.3 路侧基础设施与智能网联汽车的身份认证和鉴别功能，应符合 7.4.1 中的要求。

6.5.4 路侧基础设施接入路侧基础设施管理系统的身份认证和鉴别功能，应基于路侧基础设施唯一标识对其进行身份认证和鉴别；应具备对路侧基础设施进行周期性接入认证的能力，及时感知设备出现的认证异常。

6.5.5 路侧基础设施管理系统对用户的身份认证和鉴别功能包括：

- 1) 应对登录路侧基础设施管理系统的用户进行身份认证和鉴别，身份标识具有唯一性，身份鉴别信息具有复杂度要求并定期更换；
- 2) 应采用口令、密码技术、生物识别技术等两种或两种以上组合的鉴别技术对登录路侧基础设施管理系统的用户进行身份鉴别，且其中一种鉴别技术至少应使用密码技术来实现；使用口令鉴别方式时，应符合 6.5.1 中的要求；
- 3) 应对登录路侧基础设施管理系统的用户身份鉴别信息进行安全保护，保障用户鉴别信息存储的机密性和完整性，以及传输过程中的机密性和完整性；
- 4) 应具有登录失败处理功能，应配置并启用结束会话、限制非法登录次数，宜不超过 5 次，超过次数时，限制 5 min 后再登录和当登录连接超时自动退出等相关措施。

6.6 访问控制

6.6.1 路侧设备及应用系统访问控制要求如下：

- 1) 应对不同的用户设置不同的账户和权限；
- 2) 应依据访问数据的不同类型与安全级别进行不同的策略设计；
- 3) 不同类型安全级别的访问控制应与用户身份认证鉴别功能绑定，如基于身份的用户鉴别安全机制，增加多级控制机制；
- 4) 数据库系统与文件系统应设计用户鉴别和访问控制策略，并遵循最小授权原则对各类系统访问用户配置访问控制策略；
- 5) 访问控制策略应使用白名单机制，明确定义允许的行为，其他一切行为都将被阻止；
- 6) 应建立面向数据应用的安全控制机制，包括访问控制时效的管理和验证，以及应用接入数据存储的合法性和安全性取证机制；
- 7) 应具备登录失败处理功能，符合 6.5.5 4) 中的要求；
- 8) 访问控制策略变更时，应进行评估，经审核批准后方可实施变更，并记录操作日志；
- 9) 默认状态下应仅开启必要的服务和对应的端口，应明示所有默认开启的服务、对应的端口及用途，应支持用户关闭默认开启的服务和对应的端口；
- 10) 非默认开放的端口和服务，应在用户知晓且同意后方可开启；如建立端口监测功能，对非法开启的端口进行感知、告警；
- 11) 路侧基础设施硬件设备的外部接口、其他调试接口等应进行访问控制保护，禁止非授权用户访问。对 USB（通用串行总线）设备、移动光驱等外部存储设备应进行严格的接入管控，默认状态下接入后无法使用；
- 12) 在设备具备身份认证的基础上，访问控制可采用基于属性或者角色的访问控制策略对用户进行授权管理和访问控制；
- 13) 可建立基于设备行为的数据存储安全监测与控制机制。

6.6.2 路侧设备数据存储系统访问控制要求如下：

- 1) 应设计数据存储系统的访问控制策略和访问控制机制，对访问对象的访问范围和操作权限进行限定，确保不超出预定义的范围，且满足最小授权原则；
- 2) 应使用存储访问控制模块部署数据用户身份标识与鉴别策略、数据访问控制策略，并执行相关安全控制措施；
- 3) 不同类型安全级别的访问控制应与用户身份认证鉴别功能绑定，如基于身份的用户鉴别安全机制，增加多级控制机制。

6.7 漏洞和代码防护

- 6.7.1 系统应遵循最小安装的原则，仅安装运行需要的组件或应用程序，应使用最新的公开版本。
- 6.7.2 应通过设定接入方式、网络地址范围等方法对通过网络进行管理的终端进行限制。
- 6.7.3 不应存在权威漏洞库（如网络安全威胁和漏洞信息共享平台 NVDB、国家信息安全漏洞共享平台 CNVD、通用漏洞和风险 CVE、中国国家信息安全漏洞库 CNNVD）公开的 6 个月及以前的高危以上漏洞；针对 6 个月以内的高危以上漏洞，应在评估后于 5 日内完成修补或采取缓解措施。
- 6.7.4 宜通过代码混淆、代码加密、代码签名等技术，保护代码免受恶意攻击。

6.8 入侵检测和防御

6.8.1 入侵检测要求如下：

- 1) 应具备实时获取受保护网段内的数据包的能力用于检测分析各类恶意攻击；
- 2) 应监视整个网络或某一指定网口的报文流量和字节流量，如在流量入侵检测之外部署主机入侵检测程序，对路侧设备操作系统搜集包含但不限于进程、文件、登录信息等数据；
- 3) 应具备攻击检测与防护功能，如监测关键网络节点、检测阻断各类网络攻击行为。

6.8.2 异常分析要求如下：

- 1) 应具备对收集的网络攻击事件日志、异常流量事件、设备运行异常日志等数据进行分析、发现安全事件的能力；
- 2) 应具备避免出现告警风暴的能力。

6.8.3 入侵防御要求如下：

- 1) 当检测到入侵时，应自动采取响应动作并发出安全警告；
- 2) 在监测到网络上的非法连接时，应具备阻断能力；
- 3) 应对被检测网段中指定目的设备设置不同的响应方式；
- 4) 告警应采取屏幕实时提示、邮件通知、短信通知、系统日志等方式；
- 5) 应具备与防火墙进行联动的能力，可自动执行联动策略。

6.8.4 管理控制要求如下：

- 1) 应按照安全事件的严重程度将事件分级；
- 2) 安全事件数据中应包括事件的定义和分析内容、详细的恢复处置方案、可采取的对策等；
- 3) 应具备策略模板、支持策略的导入和导出；
- 4) 应具有远程配置终端入侵检测策略的能力。

6.8.5 安全报告要求如下：

- 1) 应记录安全事件信息，内容符合 6.4.2 中的要求；
- 2) 可通过管理界面实时查看安全事件，并生成安全事报告。

6.9 密码支持

6.9.1 路侧基础设施宜采用国家密码管理主管部门批准的商用密码算法,符合 GB/T 39786 相关要求。具体要求如下：

- 1) 身份鉴别、数字签名、密钥交换宜采用 SM2 算法，遵循 GB/T 32918（所有部分）、GB/T 35275 及 GB/T 35276 相关要求，为了保证路侧基础设施有更好的兼容性和可扩展性，可支持 RSA-2048 及以上算法；
- 2) 数据的完整性保护宜采用基于 SM4 分组密码算法或者 SM3 密码杂凑算法的消息鉴别码(MAC) 机制，遵循 GB/T 15852（所有部分）和 GB/T 32905 相关要求。为了保证路侧基础设施有更好的兼容性和可扩展性，可支持 SHA-256 及以上算法；
- 3) 数据的对称加解密计算宜采用 SM4 分组密码算法，遵循 GB/T 32907 相关要求。为了保证路侧基础设施有更好的兼容性和可扩展性，可支持 AES-256 及以上算法。

6.9.2 路侧基础设施所采用符合国家密码管理主管部门认证的密码设备。

6.9.3 路侧基础设施设备所使用的密钥必须在国家密码管理主管部门批准的密码设备内生成。路侧基础设施设备所涉及的密钥存储、分发、导入或导出、使用、备份与恢复、归档、销毁等密钥全生命周期管理应符合 GB/T 39786 相关要求。

6.9.4 路侧基础设施使用的 CA 证书应由具有合法电子认证服务许可证资质的第三方电子认证服务机构提供。

6.9.5 路侧基础设施使用的 X.509 数字证书以及 CRL 格式应遵循 GB/T 20518 相关要求，V2X 数字证书应遵循 YD/T 3957 相关要求。

7 通信网络安全要求

7.1 设备接入

7.1.1 不应存在未在产品手册中声明的无线通信服务。

7.1.2 应能够对非授权设备私自联到内部网络的行为进行检查或限制。

7.1.3 可对外部的通信连接进行身份鉴别和授权管理，在未经授权的网络设备接入时，具备发现和告警的功能，拒绝接入并记录日志。

7.2 网络传输

7.2.1 基于公共互联网的通信过程应采取安全传输协议，如 TLCP、TLS 1.2 及以上等，保障通信数据的机密性、完整性和真实性。

7.2.2 应具备针对网络传输的访问控制功能，如根据源地址、目的地址、源端口、目的端口和协议等进行检查。

7.2.3 采用的通信协议不应存在后门，应及时进行安全更新。

7.3 短距离无线通信

当路侧基础设施与外界通过蓝牙、无线局域网（WLAN）、短距离低速率无线通信（Zigbee）等方式进行短距离无线通信时，应具备启用与关闭短距离无线连接的管理功能，如手动打开、关闭短距通信连接，并对已建立无线连接的状态进行管理。

7.4 直连通信

7.4.1 发送端应采用基于数字证书的签名机制保证直连通信消息的真实性、完整性和抗抵赖性。

7.4.2 接收端应验证所接收到的其它直连通信设备发送的数据消息的证书有效性、及签名有效性，并且只对通过验证的数据进行进一步的处理；未通过验证的消息将被丢弃。

8 软件升级安全要求

8.1 升级包自身安全

8.1.1 升级包的开发者使用第三方组件应识别其涉及公开漏洞库中已知的漏洞并安装补丁，不应存在由权威漏洞平台 6 个月前公布且未经处置的高危及以上的安全漏洞。

8.1.2 升级包应采用签名认证机制保证数据的真实性和完整性。

8.1.3 升级包发布后不应包含调试功能及调试信息，不应包含敏感信息（如明文密钥、明文口令等）的接口。

8.1.4 可使用构建工具链提供的堆栈保护、自动引用计数等代码安全机制，提升升级包安全性。

8.1.5 可使用安全机制防止升级包被逆向分析。

8.2 升级时的通信安全

8.2.1 待升级设备应从安全合规的指定站点下载和安装升级包。

8.2.2 升级前，待升级设备与升级服务系统之间应经过严格的双向认证和授权，当身份认证成功后，待升级设备与升级服务系统之间才能进行业务数据的通信交互；发生身份鉴权失败、有加密要求的数据内容校验失败等情况，应终止该操作。

8.2.3 待升级设备与升级服务系统之间传输的数据内容应通过密码技术，如 TLCP 或 TLS 1.2 及以上等安全通信协议，实现机密性和完整性保护。

8.3 待升级设备安全

- 8.3.1 待升级设备应保证自身的计算环境安全。
- 8.3.2 应使用由合规的密码设备产生的安全密钥，以便建立安全通信和对服务器的安全访问。
- 8.3.3 应对外部输入的来源（如用户界面、统一资源定位符（URL）等来源）进行校验。
- 8.3.4 在接收到升级包后，应立即对其执行真实性和完整性检查，并对未通过验证的升级包执行有效处置。
- 8.3.5 应支持权限管理并遵守最小授权原则，对不同的应用软件基于实现特定功能分配不同的接口权限，不应使用 root 用户执行软件升级。
- 8.3.6 在遭遇如断电或连接中断时，应支持升级失败后的自动回滚，或支持断点续传功能，防止设备功能失效。
- 8.3.7 应在升级成功后完成功能自检和审核，保证自身健康性和过程可审核。
- 8.3.8 应建立访问控制列表 ACL，对升级包的读写执行权限予以明确，以便升级包的存储、解析、执行被认证、授权和审核。

8.4 升级操作过程安全

- 8.4.1 升级过程启动前，应确认网络连接、计算环境等基础运行条件，避免升级中断或失败。
- 8.4.2 在车流高峰期应避免执行软件升级。
- 8.4.3 升级启动时应执行自检机制，并校验软件完整性。
- 8.4.4 升级过程若需要采集和处理敏感信息，应采取安全措施确保敏感信息不被其他应用窃取。
- 8.4.5 升级过程正常退出时，应擦除缓存中的升级包镜像和文件中的敏感信息。
- 8.4.6 升级过程中途失败时，应确保将系统恢复到最近的可用版本或将系统置于安全状态。
- 8.4.7 不论升级成功与否，都应对升级过程记录日志，并采取访问控制机制管理日志读取和写入的权限。
- 8.4.8 若待升级设备无法继续存储或更新日志时，应对日志文件进行安全转储。

9 数据安全要求

9.1 数据基础安全

- 9.1.1 路侧基础设施涉及的数据应进行分类分级，根据不同的数据类别进行相应的安全性保护。
- 9.1.2 应分别从数据采集、数据存储、数据传输、数据加工、数据提供、数据销毁等数据全生命周期进行相应的安全性保护，在数据不同阶段进行数据完整性、真实性、机密性保护。
- 9.1.3 根据数据类别及各类业务对数据的使用需要，确定数据存储所必需的最短时间期限。

9.2 数据完整性与真实性

- 9.2.1 数据采集阶段可按照 6.5.2 中的要求对采集设备进行身份认证和鉴别，保证采集数据来源的真实性。
- 9.2.2 数据采集阶段可采用数据校验等机制，如基于对称密码算法或密码杂凑算法的消息鉴别码（MAC）机制的密码技术，保证采集数据的完整性。
- 9.2.3 数据传输阶段可采用基于对称密码算法或密码杂凑算法的消息鉴别码（MAC）机制、基于公钥密码算法的数字签名机制等密码技术实现传输数据的完整性保护。
- 9.2.4 数据存储阶段应采用基于对称密码算法或密码杂凑算法的消息鉴别码（MAC）机制、基于公钥密码算法的数字签名机制等密码技术确保重要数据存储过程中的完整性，并在检测到完整性错误时采取必要的恢复措施。

9.3 数据机密性

9.3.1 数据传输阶段应采用密码技术实现关键数据、鉴别数据和其他重要数据传输的机密性，在进行加密时应采用如 AES-256、SM4 等加密算法。

9.3.2 身份鉴别如采用密码技术，鉴别数据应采用安全机制（如安全芯片、密码模块等）保护。

9.3.3 重要数据应存储在安全区域或以密文形式存储。

9.3.4 重要数据应采用安全机制防止泄漏，如采用加密、脱敏等方法。

9.3.5 数据传输过程中，应对数据发送方和接受方实施身份认证，在建立连接前，利用密码技术进行初始化会话验证，必要时采用经认证的安全传输协议或标准安全协议服务（TLCP 或 TLS 1.2 及以上），避免来自基于协议的攻击和破坏。

参 考 文 献

- [1] GB/T 22239 信息安全技术 网络安全等级保护基本要求
 - [2] GB 40050 网络关键设备安全通用要求
 - [3] GB/T 40856 车载信息交互系统 信息安全技术要求及试验方法
 - [4] GB/T 40861 汽车信息安全通用技术要求
 - [5] GB/T 44464 汽车数据通用要求
 - [6] GB 44495 汽车整车信息安全技术要求
 - [7] GB 44496 汽车软件升级通用技术要求
 - [8] YD/T 3594 基于LTE的车联网通信安全技术要求
 - [9] YD/T 3707 基于LTE的车联网无线通信技术 网络层技术要求
 - [10] YD/T 3709 基于LTE的车联网无线通信技术 消息层技术要求
 - [11] YD/T 3751 车联网信息服务 数据安全技术要求
 - [12] YD/T 3755 基于LTE的车联网无线通信技术 支持直连通信的路侧设备技术要求
-